SECURITY ARCHITECTURE PORTFOLIO

Orthogonal Systems Invariance Method

A systems-based framework for designing, enforcing, and validating security architectures under adversarial conditions

ZERO TRUST ALIGNED	DEFAULT-DENY ENFORCEMENT	MACHINE-VERIFIABLE INVARIANTS	RED TEAM VALIDATED

Alec Sanchez
Principal Author — OSIM Framework

2026 · Version 1.0

TABLE OF CONTENTS

Portfolio Structure

01 — Security Philosophy
- The architecture problem
- OSIM design thesis
- Core commitments

02 — Framework Overview
- What OSIM is
- The orthogonality property
- The invariance property

03 — Architectural Principles
- Eight design principles
- P-01 through P-08

04 — Security Invariants
- Invariant definition
- INV-01 through INV-10
- Verification cadence

05 — Reference Network Architecture
- Zone model
- Trust tier classification
- VLAN architecture diagram

06 — Firewall Enforcement Model
- Rule taxonomy
- Alias architecture
- Rule evaluation flow

07 — Detection and Monitoring
- Detection layer model
- Wazuh architecture
- Suricata IDS/IPS

08 — Threat Model and Control Mapping
- Boundary threat analysis
- ATT&CK; mapping
- Risk register

09 — Homelab Reference Implementation
- Platform components
- Reference environment topology
- Traffic flow model

10 — Detection Engineering Strategy
- Validation scenarios RT-01/02/03
- Evidence chain
- Baseline metrics

11 — Governance and Change Management
- Firewall as code
- Config hash governance
- Invariant audit

12 — Architecture Evolution Roadmap
- Current residual risks
- Maturity roadmap
- Zero Trust evolution

SECTION 01

Security Philosophy

Security architecture fails in predictable ways. Networks are flattened to reduce operational friction. Firewall rules accumulate without governance. Trust is granted implicitly by zone membership rather than explicitly by policy. Monitoring is bolted on after the fact rather than designed in from the start. When a host is compromised, the question is not whether the attacker can pivot — it is how far.

The Architecture Problem

The dominant failure mode in enterprise network security is not a failure of detection. It is a failure of structural containment. Detection systems generate alerts. Analysts investigate. But by the time detection fires, an attacker who has already moved laterally from a compromised endpoint to a hypervisor, a domain controller, or a backup system has already achieved their objective. Detection without containment is forensics, not security.

The second failure mode is governance decay. Security policies are written, then eroded. Rules are added without review. Exceptions become permanent. Within months of deployment, the actual enforced policy diverges from the intended policy, and nobody can determine what the current security posture actually is without manual inspection of every rule on every device.

> **Core Design Thesis:**
> Security boundaries must be enforced structurally — at the network layer, not by software policy on endpoints. Security properties must be expressed as machine-verifiable invariants, not as documentation. Governance must be automated, not aspirational. Detection must confirm that structural controls are working, not substitute for them.

OSIM Design Thesis

The Orthogonal Systems Invariance Method is built on a single observation: the most durable security architectures are those where security properties are structurally enforced rather than operationally maintained. A firewall rule that blocks lateral movement does not require an analyst to notice the movement, triage an alert, and take action. It blocks the movement regardless of analyst availability, regardless of attacker sophistication, and regardless of whether the target endpoint's host-based controls have been disabled.

This principle — security through structural enforcement — is not new. Zero Trust architecture makes the same argument at the identity layer. Network segmentation has been understood since the 1990s. What

OSIM contributes is a complete methodology that integrates structural enforcement, invariant verification, operational validation, and governance tooling into a single coherent system — applicable at any scale, on commodity hardware, with open-source tooling.

Core Commitments

- **Structural enforcement over operational vigilance.** Architectural controls that work automatically are more reliable than operational controls that depend on human attention at the right moment.
- **Explicit policy over implicit trust.** Every permitted communication path is documented, justified, and expressed as a discrete rule. The absence of a rule means block, not allow.
- **Verifiable correctness over assumed compliance.** Security properties are expressed as machine-checkable invariants. A property that cannot be verified cannot be relied upon.
- **Governance as engineering discipline.** Firewall configurations are versioned artifacts. Changes require review, documentation, and post-change invariant verification.
- **Detection confirms, it does not substitute.** The SIEM and IDS are validation systems for structural controls, not replacements for them.

SECTION 02

Framework Overview

OSIM defines the architecture, governance, and validation procedures for environments that must maintain defensible isolation under adversarial conditions. The framework is structured around two foundational properties that give it its name.

The Orthogonality Property

In linear algebra, orthogonal vectors are independent — movement along one axis produces no movement along another. OSIM applies this concept to security zones: a compromise within one zone produces no automatic capability gain in any other zone. The zones are architecturally independent. An attacker who fully owns a LAB host cannot reach the hypervisor, the firewall console, or the SIEM because the firewall structurally prevents those connections — not because the LAB host has a well-configured host firewall, not because the credentials are rotated, but because the network path does not exist from the firewall's perspective.

The Invariance Property

Security invariants are binary, machine-verifiable properties of the system configuration that must remain true at all times. INV-01 through INV-10 express the critical security properties of the OSIM reference architecture as testable conditions against the live configuration. Invariant verification is integrated into change management: no change is complete until all invariants are confirmed true. An invariant that becomes false is treated as a critical governance event requiring immediate investigation, not a routine configuration issue.

Comparison to Existing Frameworks

Framework	Relationship to OSIM
NIST Zero Trust (SP 800-207)	OSIM is Zero Trust at the network layer. Both reject implicit trust. OSIM adds structural enforcement via firewall policy rather than relying solely on identity-aware proxies.
NIST SP 800-41 (Firewall Policy)	OSIM extends the firewall policy guidance with an invariant model, alias architecture requirements, and automated governance tooling.
MITRE ATT&CK;	OSIM maps every enforced boundary to specific ATT&CK; technique IDs. Validation scenarios are ATT&CK-aligned.; Red team exercises declare techniques before execution.
Defense in Depth	OSIM implements defense in depth structurally: four detection layers (structural, network, content, behavioral) each independently capable of catching what the layer below misses.

Framework	Relationship to OSIM
CIS Controls	OSIM aligns to CIS Controls 12 (Network Infrastructure Management), 13 (Network Monitoring), and 14 (Security Awareness) at the architectural level.

SECTION 03

Architectural Principles

Eight principles that govern the construction of any OSIM-conformant architecture.

P-01 — Separation of Trust Tiers

Administrative workstation infrastructure and privileged control-plane infrastructure must reside on separate network segments with explicit, port-scoped communication rules between them. A compromised administrative workstation must not produce unrestricted access to hypervisor management interfaces, firewall consoles, or backup infrastructure. The workstation tier and the infrastructure tier are separate VLANs with separate gateway IPs and separate interface rule sets.

P-02 — Detection Plane Isolation

The SIEM and monitoring infrastructure reside in a zone that accepts inbound telemetry from all zones but initiates no management sessions into those zones. The detection plane must survive the compromise of any other zone without losing visibility or operational capability. Active response is executed by agents on monitored hosts — the detection plane never SSHes into the control plane under any circumstance.

P-03 — Compromise Domain Containment

Zones used for security testing, adversary simulation, or workload operations are restricted to outbound channels strictly necessary for function. No compromise domain host initiates connections to administrative, infrastructure, or detection-plane zones except on explicitly permitted telemetry ports. The terminator rule is the sole enforcer — no intermediate block rules are required, eliminating rule-ordering fragility.

P-04 — Logging at Every Enforcement Point

Every block action at every enforced boundary produces a logged event. Silent blocks are a governance failure. The logging pipeline is validated during acceptance testing and its continued operation is confirmed through detection metric baselining. A drop in deny event volume below the established baseline triggers an alert — it indicates the logging pipeline has failed, not that the environment has become more secure.

P-05 — Alias-Based Rule Construction

All firewall rules reference named aliases for source addresses, destination addresses, and ports. Hard-coded IPs in rule definitions are prohibited. Alias-based rules are auditable, maintainable, and bulk-updatable — adding a host to NET_MGMT_B includes it in all rules referencing that alias without manual synchronization across rules.

P-06 — DNS Resolver Confinement

All internal hosts are restricted to the designated internal DNS resolver. Direct queries to external resolvers are blocked at the network layer for all zones via a floating rule. This control prevents DNS-based exfiltration and command-and-control and forces all DNS through an infrastructure-controlled resolver that can be logged and subjected to response policy zone filtering.

P-07 — IDS on the Trunk Interface

Intrusion detection is deployed on the trunk interface upstream of VLAN sub-interface de-encapsulation, with VLAN-aware configuration enabled. IDS signature matching operates on de-encapsulated Layer 3/4 content. Alerts carry source VLAN context for zone-aware triage. VLAN de-encapsulation is verified by confirming the 'vlan' field appears in eve.json alert output — absence of the field indicates the IDS is operating on raw 802.1Q frames and content-based detection is silently absent.

P-08 — Governance-First Change Management

Every rule addition, modification, or removal is accompanied by a documented justification, a configuration hash comparison, and a post-change invariant verification. The firewall configuration is a versioned artifact committed to version control. A daily hash comparison detects unauthorized changes. No change is complete until the invariant check returns all TRUE.

SECTION 04

Security Invariants

Binary, machine-verifiable properties that must remain true at all times.

Security invariants are the most direct expression of OSIM's core commitment to verifiable correctness. Unlike a policy document that describes intended behavior, an invariant is a testable condition against the live system state. Either it is true or it is violated — there is no middle ground. An invariant violation is not a configuration issue to be scheduled for remediation. It is a critical governance event that requires immediate investigation and resolution before the change that caused it can be considered complete.

Invariant Set — INV-01 through INV-10

ID	Invariant	Enforcement Mechanism	Status
INV-01	No ANY-ANY pass rule on any interface	`All-interface terminator rules MA-99 through S-99`	ENFORCED
INV-02	MGMT-A→MGMT-B restricted to ports 8006, 22, 443 only	`MA-08 explicit block + MA-99 terminator`	ENFORCED
INV-03	No DMZ→internal pass except Wazuh agent ports	`D-99 terminator; D-01/D-02 to HOST_WAZUH only`	ENFORCED
INV-04	Every interface ends with logged block-all terminator	`MA-99, MB-99, L-99, D-99, S-99`	ENFORCED
INV-05	DNS-BLOCK floating rule active on all internal VLANs	`Alias DNS_RESOLVERS + single-negation floating rule`	ENFORCED
INV-06	Suricata VLAN tracking enabled on trunk interface	`suricata.yaml vlan:use-for-tracking:true`	ENFORCED
INV-07	No pass rule: NET_LAB or NET_DMZ → NET_MGMT_B	`L-99 and D-99 terminators`	ENFORCED
INV-08	Wazuh agents active across all five VLANs	`Agent config + per-VLAN Wazuh permit rules`	ENFORCED
INV-09	config.xml SHA-256 matches Git baseline	`Daily cron hash comparison + Wazuh drift alert`	MONITORED
INV-10	SECURITY never initiates SSH to control plane	`S-08 and S-09 explicit block rules`	ENFORCED

Table 1. OSIM Security Invariant Set with Verification Mechanisms

Invariant Verification Cadence

Verification Type	Method	Trigger
Automated script	Parse config.xml against invariant conditions; query Wazuh API for agent status; check suricata.yaml	Every config change + weekly scheduled run
Config hash check	SHA-256 of live config.xml compared to Git-committed baseline	Daily cron; mismatch triggers Wazuh alert (INV-09)
Manual audit	Engineer reviews OPNsense rule list and alias table against invariant set	Quarterly + after any major infrastructure change
Red team confirmation	RT-01, RT-02, RT-03 exercises collectively verify INV-01 through INV-07	Per exercise cycle (minimum quarterly)
SIEM baseline check	Alert volume metrics compared to established 30-day rolling baselines	Daily automated dashboard + immediate alert on anomaly

Table 2. Invariant Verification Cadence and Methods

SECTION 05

Reference Network Architecture

Five-zone segmentation model with trust tier classification.

The OSIM reference network architecture defines five canonical security zones organized across a three-tier trust hierarchy. The zone model is designed to reflect real enterprise conditions: a management tier that controls infrastructure, a workload tier that handles operations, a perimeter tier that faces the internet, and a detection tier that observes all others without being reachable from any of them.

Zone Communication Matrix

Zone	VLAN	Subnet	Trust Tier	Inbound From	Outbound To
MGMT-A (Admin WS)	10	`10.10.10.0/24`	**Tier 0-User**	Operator only (no WAN)	MGMT-B (ports 8006/22/443) SECURITY (Wazuh API) LAB/DMZ (admin ports) Internet (443/80)
MGMT-B (Infra)	11	`10.10.11.0/24`	**Tier 0-Infra**	MGMT-A on explicit ports only	SECURITY (Wazuh agent) LAB/DMZ (backup port 9090) Internet (443 updates)
LAB (Compromise)	20	`10.10.20.0/24`	**Tier 2**	MGMT-A admin ports only	SECURITY (Wazuh 1514/1515) DMZ proxy (80/443) Internet (443/80)
DMZ (Exposed)	30	`10.10.30.0/24`	**Tier 1-Ext**	WAN 80/443 → Reverse proxy only	SECURITY (Wazuh 1514/1515) Internet (443/587)
SECURITY (Detection)	40	`10.10.40.0/24`	**Tier 0-Det**	All zones: Wazuh ports only	LAB/DMZ active response Internet (threat intel) NO control plane access

Table 3. Zone Communication Matrix — Permitted Inbound and Outbound Flows

VLAN Architecture Diagram

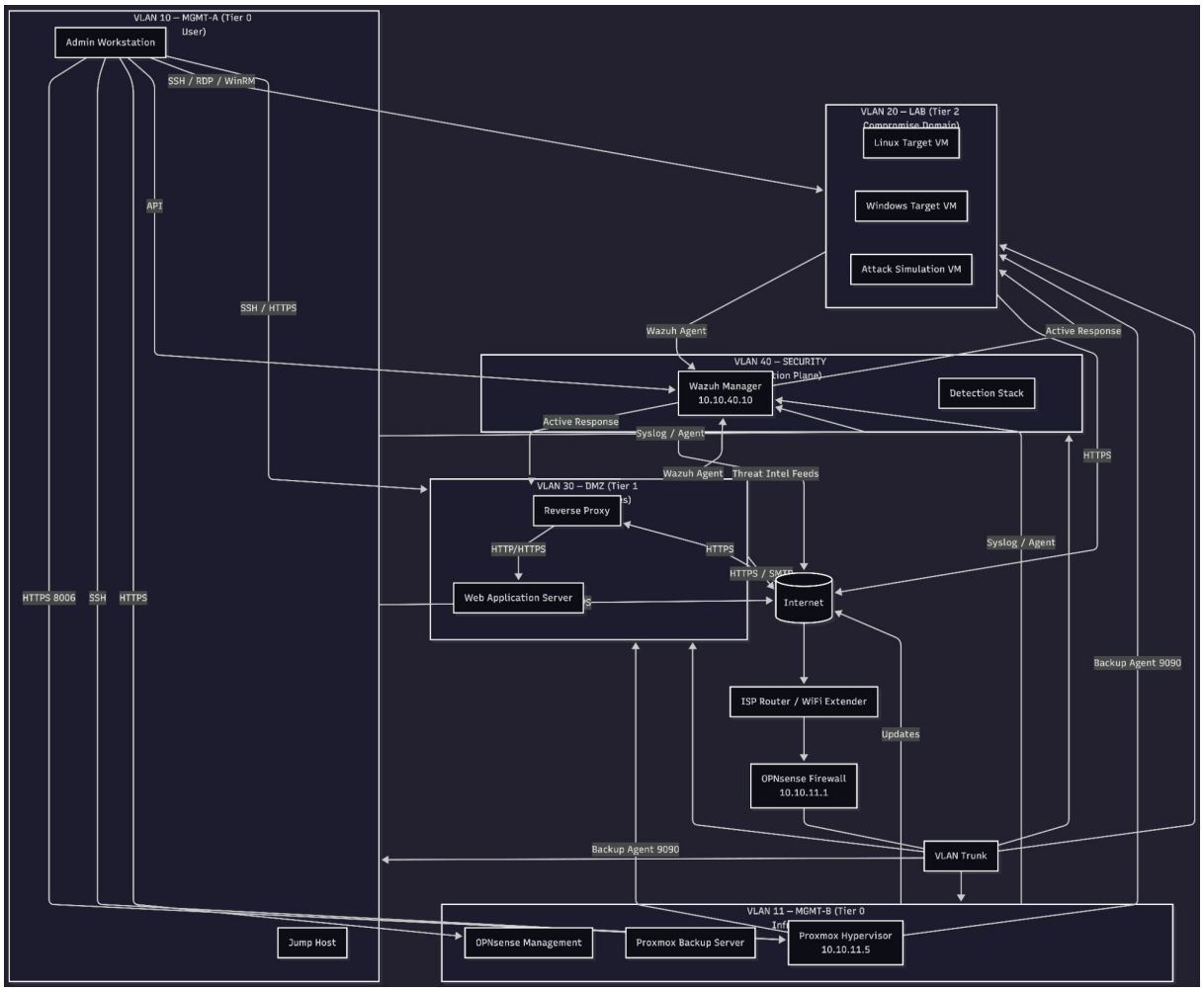

Figure 1. OSIM Five-Zone VLAN Architecture — Trust Tiers, Subnets, and Inter-Zone Communication Paths

Logical Plane Model

The logical plane model abstracts the physical VLAN architecture into four functional planes — Management, Control, Workload, and Evidence — and the Firewall Policy Engine that mediates communication between them. This abstraction clarifies the directional trust model: the Management plane has administrative access to all other planes; the Control plane pushes policy to the Workload plane; the Workload plane forwards telemetry to the Evidence plane; the Evidence plane returns only active response commands to the Workload plane. No plane has unrestricted access to any other.

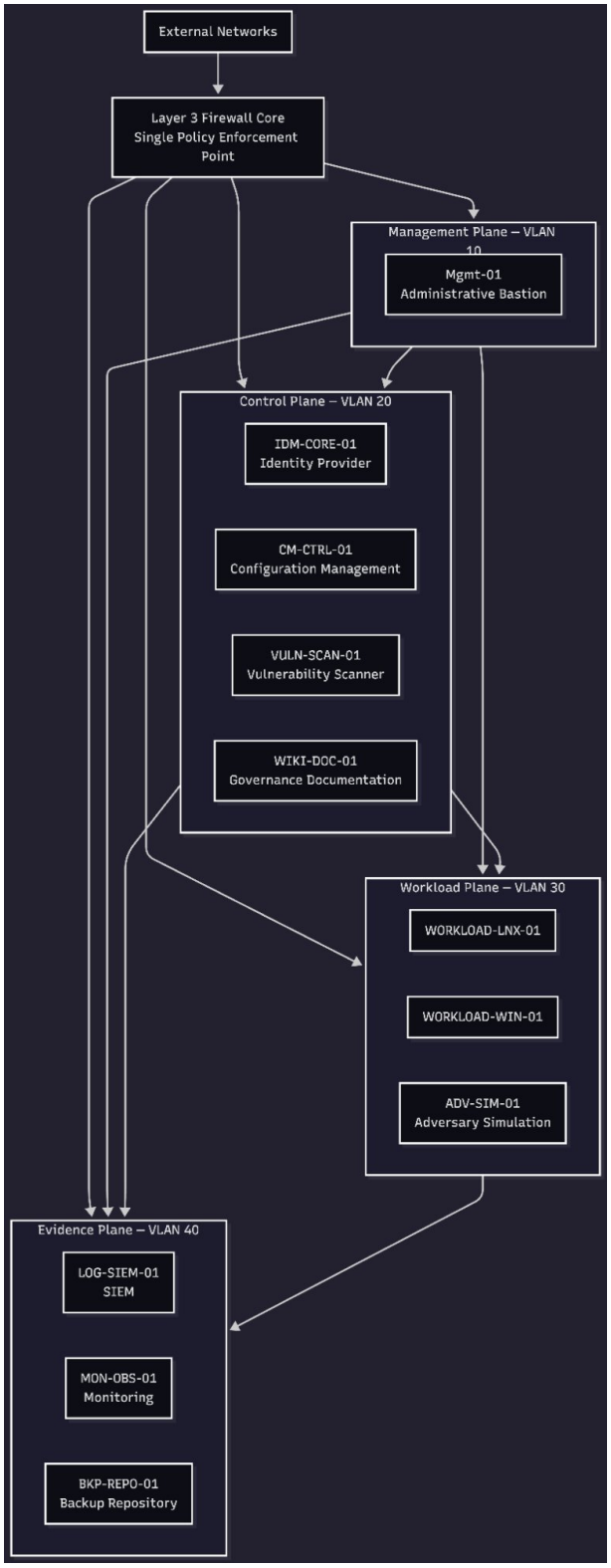

Figure 2. OSIM Logical Plane Architecture — Directional Trust and Control Flow Model

SECTION 06

Firewall Enforcement Model

Rule taxonomy, alias architecture, and the default-deny terminator model.

The firewall is the primary structural enforcement mechanism in OSIM. It is not a perimeter control — it is a zone boundary enforcement point for every inter-zone communication path in the environment. Every VM-to-VM communication crosses the firewall. Every permitted path is explicitly documented. Every denied path is logged.

Rule Evaluation Flow

OPNsense evaluates rules top-to-bottom, first-match-wins, per interface. OSIM prescribes a mandatory ordering template that ensures telemetry flows are never shadowed by subsequently added rules and that the terminator is always the final evaluator for unmatched traffic.

STEP	EVALUATION POINT	MATCH CONDITION	ACTION	LOG
1	Interface ingress — source VLAN	Wazuh agent ports (1514/1515/514)	PASS	NO
2	Interface ingress — intra-zone	Source and destination in same zone subnet	PASS	VARIES
3	Interface ingress — inter-zone explicit	Named alias match on src/dst/port	PASS	YES
4	Interface ingress — internet egress	Destination not in NET_ALL_INTERNAL	PASS	YES
5	Interface ingress — infra services	DNS/NTP to gateway IP only	PASS	NO
6	Interface ingress — TERMINATOR	Any remaining unmatched traffic	BLOCK	YES

Figure 3. OSIM Firewall Rule Evaluation Flow — Per-Interface Ordering Template

The Terminator Rule

Design Rationale — Why Terminators, Not Intermediate Blocks:
Earlier versions of OSIM policy used explicit intermediate block rules to deny specific cross-zone paths (e.g., LAB→MGMT, LAB→SECURITY). This approach is fragile: a new PASS rule inserted above a block rule silently nullifies the block without generating any error. The v1.1.0 revision replaced all intermediate block rules with reliance on the per-interface terminator. The terminator at the bottom of each interface denies everything not explicitly permitted above it. Adding a new PASS rule above the terminator is the only way to permit new traffic — there is no accidental bypass mechanism. This eliminates an entire class of policy ordering vulnerabilities.

Alias Architecture

All rules reference named aliases. No rule contains a hard-coded IP address or port number. The alias taxonomy follows a strict naming convention:

Alias Prefix	Type	Examples	Purpose
NET_[ZONE]	Network	NET_MGMT_A, NET_LAB, NET_DMZ	Zone subnet — used in source/destination fields
HOST_[FUNCTION]	Host	HOST_PROXMOX, HOST_WAZUH, HOST_DMZ_PROXY	Specific host IP — enables host-scoped rules
PORT_[SERVICE]	Port	PORT_WAZUH_AGENT, PORT_PROXMOX_UI, PORT_SSH	Service port group — simplifies rule maintenance
DNS_RESOLVERS	Network	All five VLAN gateway IPs	Used in DNS-BLOCK floating rule negation
RFC1918_ALL	Network	10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16	Anti-spoofing and egress scope control
NET_ALL_INTERNAL	Network	All five zone subnets	Negated in internet egress rules (!NET_ALL_INTERNAL)

Table 4. OSIM Alias Naming Convention and Taxonomy

DNS Leak Prevention

A single floating rule enforces DNS resolver confinement across all internal VLANs: block outbound UDP/TCP port 53 where the destination is NOT in the DNS_RESOLVERS alias. This prevents any internal host from querying an external resolver — a common exfiltration and C2 channel. All DNS traffic is forced through Unbound, which can be logged, rate-limited, and subjected to response policy zone filtering. OPNsense requires single-alias negation syntax; multi-negated destination fields are not parsed correctly and silently produce no rule.

Inter-Plane Traffic Flow

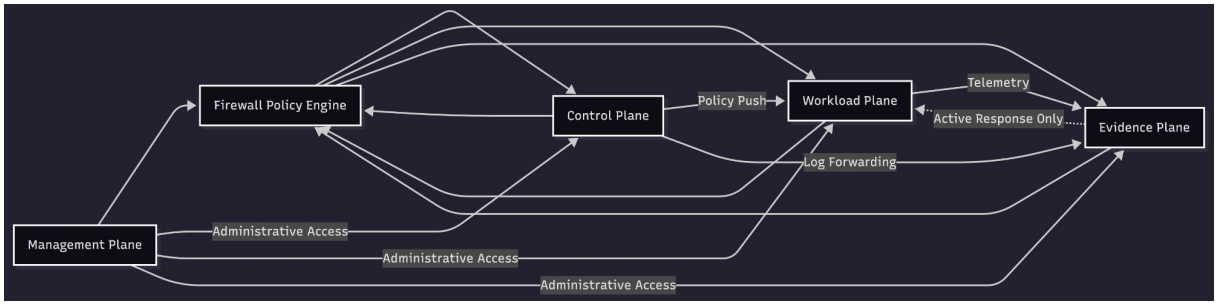

Figure 4. OSIM Inter-Plane Traffic Flow — Permitted Directional Channels Between Planes

SECTION 07

Detection and Monitoring Architecture

Four detection layers operating in depth from structural enforcement to behavioral correlation.

Detection in OSIM is designed as a four-layer model where each layer operates independently and catches what the layer below may miss. The structural layer is the most reliable — it enforces by blocking. The behavioral layer is the most sensitive — it detects by correlating. Neither layer is sufficient alone, and no layer substitutes for the others.

Detection Control Layers

LAYER 4 — BEHAVIORAL	Wazuh correlation rules · Active response · Threat intel enrichment
LAYER 3 — CONTENT	Suricata IDS/IPS · ET Open signatures · JA3 TLS fingerprinting · DNS anomaly detection
LAYER 2 — NETWORK	Firewall deny logging · DNS-BLOCK floating rule · IDS VLAN tagging · NAT transparency
LAYER 1 — STRUCTURAL	Default-deny terminators · Zone isolation · Explicit-allow only · No ANY-ANY rules

Figure 5. OSIM Detection Control Layer Model — Structural through Behavioral

Wazuh SIEM Architecture

Wazuh Manager resides exclusively on VLAN 40 (SECURITY). It accepts inbound telemetry on ports 1514/1515 (agent events) and 514 (syslog) from all five zones. The SECURITY zone rule set permits inbound agent traffic from NET_ALL_INTERNAL to HOST_WAZUH only on those specific ports. Any other inbound connection to HOST_WAZUH is denied by S-05 and logged. Wazuh initiates no outbound connections to any zone except active response commands on agent ports to LAB and DMZ — and only from HOST_WAZUH specifically, not from the broader NET_SECURITY range.

OPNsense firewall logs are shipped to Wazuh via syslog UDP/514 from the MGMT-B interface. Suricata eve.json alerts are shipped to Wazuh via the agent installed on the OPNsense host. Both telemetry streams arrive in Wazuh with full field mapping, enabling correlation between firewall deny events and IDS signature fires on the same traffic.

Suricata IDS/IPS

Suricata is deployed on the trunk interface (vtnet1) upstream of VLAN sub-interface processing. This placement means Suricata inspects all inter-zone traffic before it reaches the sub-interface where the firewall rules apply. VLAN tracking is enabled via the suricata.yaml configuration, causing Suricata to strip 802.1Q tags before signature matching. The resulting eve.json alerts include a 'vlan' field with the source VLAN identifier — enabling zone-aware alert triage in Wazuh.

Ruleset Category	Coverage	Anomaly Threshold
ET DNS	DNS tunneling, high-entropy subdomains, C2 beacon patterns, excessive query volume	ET DNS alerts > 20/day
ET MALWARE	Known C2 framework TLS fingerprints (JA3), Meterpreter patterns, payload indicators	ET MALWARE > 10/day
ET POLICY	Protocol anomalies, non-standard port usage, policy violations on permitted channels	ET POLICY > 50/day
ET WEB_SERVER	Web application attack signatures, SQLi, XSS, RFI on DMZ reverse proxy traffic	ET WEB > 30/day
Suricata Custom	Internal-baseline suppression list; SID suppressions require documented justification	0 undocumented suppressions

Table 5. Suricata Ruleset Categories and Alert Thresholds

Alert Volume Baselines

Metric	Normal Range (30-day)	Anomaly	Action
Firewall deny events — total	50–200 / day	< 10 or > 2,000	Below: pipeline check. Above: scan investigation.
Deny — LAB→MGMT-B (L-99)	0–5 / day	> 20 / day	Pivot attempt. Investigate source host immediately.
Deny — DMZ→internal (D-99)	0–10 / day	> 30 / day	Post-exploitation indicator. High priority.
Deny — DNS-BLOCK	0–2 / day	> 10 / day	DNS C2 / tunneling attempt.
Suricata IDS — total	10–100 / day	< 1 or > 1,000	Below: engine failure. Above: active outbreak.
Wazuh agent failures — DMZ	0 / day	> 0	Unexpected. Review immediately.
OPNsense syslog to Wazuh	500–5,000 / day	< 50 / day	Syslog pipeline break.

Table 6. Detection Metric Baselines and Anomaly Thresholds

SECTION 08

Threat Model and Control Mapping

Boundary-level threat analysis mapped to MITRE ATT&CK; and enforcing controls.

The OSIM threat model is organized around adversary position and lateral movement objectives. The primary threat scenarios are: a compromised host in a lower-trust zone pivoting to a higher-trust zone; an internet-facing service attempting inward callback; an attacker abusing permitted protocol channels for exfiltration or C2; and an insider or compromised admin workstation attempting unrestricted infrastructure access. Every enforced boundary maps to specific ATT&CK; technique IDs that it prevents or degrades.

ATT&CK; Technique to Control Mapping

Boundary	ATT&CK; ID	Technique	Control Type	Enforcing Rule
LAB → MGMT-B	`T1021.004`	Remote Services: SSH	**Structural Block**	`L-99 terminator`
LAB → MGMT-B	`T1611`	Escape to Host (Proxmox API)	**Structural Block**	`L-99 + MB-99`
LAB → MGMT-B	`T1078`	Valid Accounts — hypervisor	**Structural Block**	`L-99 terminator`
LAB → MGMT-A	`T1563`	Remote Session Hijacking	**Structural Block**	`L-99 terminator`
LAB → SECURITY	`T1562.001`	Disable or Modify Tools	**Structural Block**	`L-99; explicit Wazuh-only`
LAB → SECURITY	`T1070`	Indicator Removal	**Structural Block**	`L-99 terminator`
DMZ → LAB	`T1090.003`	Multi-hop Proxy (C2 relay)	**Structural Block**	`D-99 terminator`
DMZ → MGMT-B	`T1190`	Exploit Public-Facing → Pivot	**Structural Block**	`D-99 terminator`
WAN → MGMT	`T1133`	External Remote Services	**Structural Block**	`W-IN-02 default deny`
All VLANs	`T1048.003`	Exfiltration Over DNS	**Network + Detection**	`DNS-BLOCK + Suricata ET DNS`
All VLANs	`T1071.004`	C2 via DNS	**Network + Detection**	`DNS-BLOCK + Suricata ET DNS`
LAB/DMZ Egress	`T1071.001`	C2 over HTTPS	**Detection Only**	`Suricata JA3 + ET MALWARE`
SECURITY → MGMT-B	`T1219`	Remote Access Software Pivot	**Structural Block**	`S-08, S-09 explicit block`

Boundary	ATT&CK; ID	Technique	Control Type	Enforcing Rule
Intra-DMZ	`T1570`	Lateral Tool Transfer	**Structural Block**	`D-05 intra-DMZ block`

Table 7. OSIM Threat Boundary — ATT&CK; Technique and Control Mapping

Risk Register

Two residual MEDIUM risks are formally accepted at current architecture maturity. Both have documented mitigation paths in the Architecture Evolution Roadmap (Section 12). All other boundaries carry LOW residual risk.

Risk Scenario	Inherent	Controls	Residual	Owner
LAB → MGMT-B hypervisor pivot	HIGH	L-99 terminator; VLAN isolation; Wazuh alert on deny	LOW	NetSec
DMZ → internal pivot post-exploitation	HIGH	D-99 terminator; no inward pass rules; Suricata egress inspection	LOW	NetSec
MGMT-A → MGMT-B lateral (workstation compromise)	HIGH	MA-08 port restriction (8006/22/443); separate VLANs; Wazuh host logging	MEDIUM*	NetSec/IAM
DNS exfiltration / C2 via DNS	MEDIUM	DNS-BLOCK floating rule; Suricata ET DNS; Unbound logging	LOW	NetSec/SOC
HTTPS C2 egress from LAB or DMZ	MEDIUM	Suricata JA3 fingerprinting; ET MALWARE signatures; certificate anomaly rules	MEDIUM*	SOC
SIEM disruption (LAB → SECURITY)	HIGH	L-99 terminator; Wazuh ports explicit-only; agent-based active response	LOW	SOC
WAN-initiated access to internal zones	HIGH	W-IN-02 default deny; no management IPs reachable from WAN; DMZ proxy only	LOW	NetSec
Suricata IDS silent failure (VLAN misconfig)	HIGH	Section 12.1 7-step verification; eve.json VLAN field check; alert baseline monitoring	LOW	SOC
Config drift (undocumented changes)	MEDIUM	Daily config.xml hash check; INV-09; Git baseline; Wazuh drift alert	LOW	NetSec

Table 8. Risk Register — Inherent Risk, Controls, and Residual Risk

** MEDIUM residual risk — accepted at current maturity with documented mitigation path. See Section 12 for remediation roadmap.*

SECTION 09

Homelab Reference Implementation

OSIM applied to a five-zone enterprise simulation environment.

The homelab-001 reference implementation demonstrates that OSIM-conformant architecture is achievable on commodity virtualization hardware with open-source security tooling. The environment is designed not as a personal hobby project but as a controlled infrastructure platform for security architecture development, adversary simulation, and operational governance practice. Every design decision references the OSIM framework principles and is documented with engineering rationale.

Platform Components

Component	Platform	OSIM Role
Firewall / Policy Engine	OPNsense 24.x (FreeBSD 14)	Primary structural enforcement; stateful pf + Suricata IDS/IPS on trunk; all inter-zone traffic enforcement
Hypervisor	Proxmox VE (latest stable)	VM host on VLAN 11 (MGMT-B); Tier 0-Infra; management IP 10.10.11.5
SIEM / EDR Platform	Wazuh Manager (current LTS)	Detection plane anchor; 10.10.40.10 (VLAN 40); receives telemetry from all five zones
IDS Engine	Suricata on vtnet1 trunk	Layer 3 content inspection; ET Open rulesets; VLAN-aware; eve.json to Wazuh agent
DNS Resolver	Unbound (OPNsense built-in)	All VLAN gateway IPs; DoT upstream; forced via DNS-BLOCK floating rule
Backup Platform	Proxmox Backup Server (PBS)	Agent polling from MGMT-B on port 9090 to LAB and DMZ VMs
Reverse Proxy	Nginx / Caddy (VLAN 30)	Single internet-facing entry point; TLS termination; 10.10.30.11
Documentation	Wiki.js (VLAN 20)	Governance documentation platform; all policy and architecture documentation
Adversary Simulation	ADV-SIM-01 (VLAN 30)	Red team execution host; validation scenario source

Table 9. homelab-001 Platform Components and OSIM Roles

Reference Environment Topology

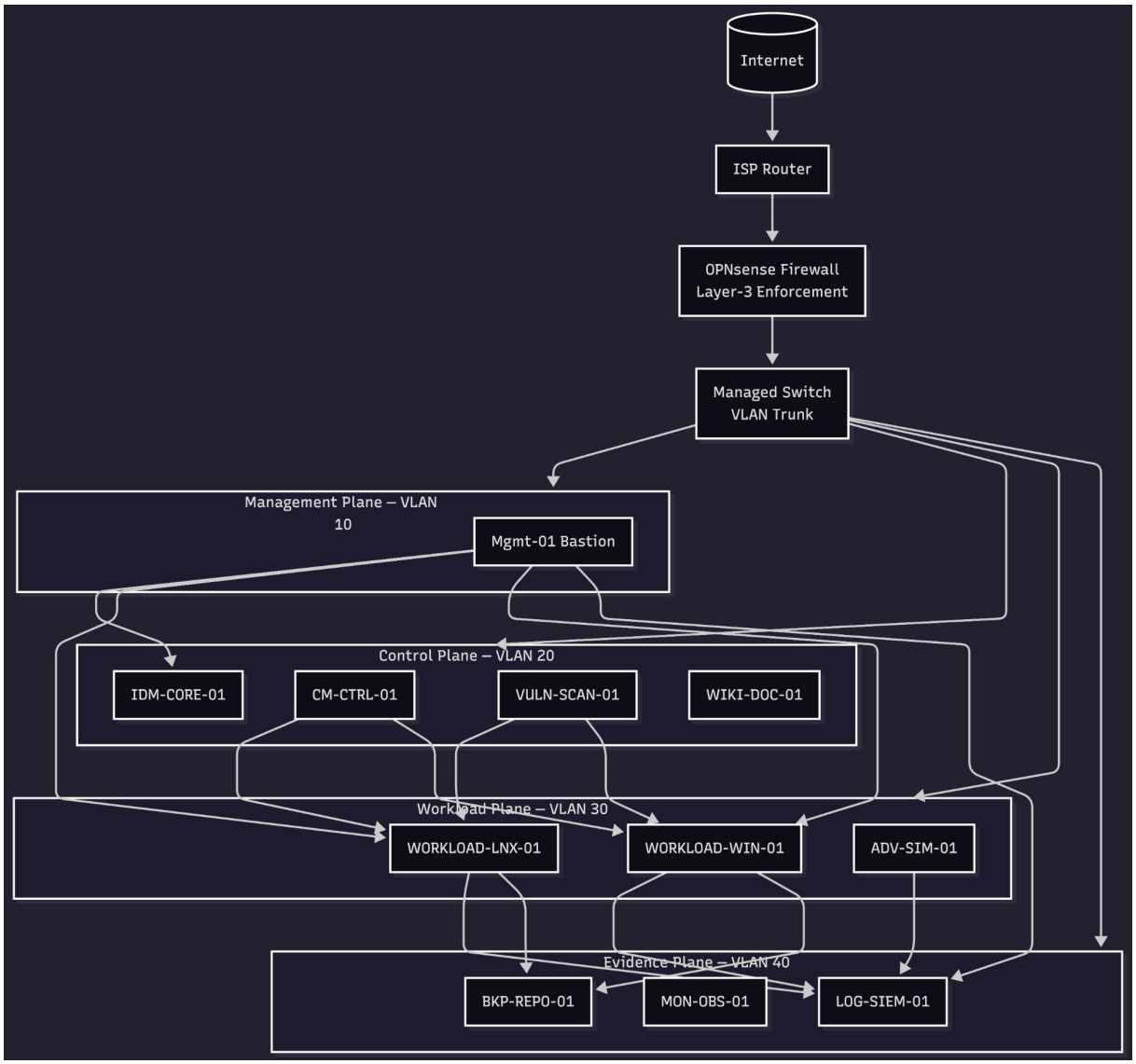

Figure 6. homelab-001 Reference Environment — Complete Physical and Virtual Layer Topology

SECTION 10

Detection Engineering Strategy

Structured validation scenarios that confirm structural controls and detection coverage.

Detection engineering in OSIM is not a passive monitoring activity. It is an active engineering discipline that treats detection coverage as a measurable property of the system, validates that coverage through structured exercises, and treats gaps as engineering defects requiring remediation. A validation exercise that produces a firewall block but no SIEM alert is a failure — both conditions must be satisfied.

Adversary Simulation Evidence Chain

Figure 7. Adversary Simulation Evidence Chain — ADV-SIM-01 through Control Validation Evidence

Validation Scenarios

Scenario	ATT&CK; Techniques	Adversary Position	Pass Criterion
RT-01 LAB → MGMT-B Pivot	T1021.004, T1611, T1078	Any VM on VLAN 20 (LAB)	TCP timeout on ports 8006, 22, 443 to MGMT-B IPs + Wazuh deny alert within 60s
RT-02 DNS Exfil / C2	T1048.003, T1071.004	Any VM on VLAN 20 or 30	External DNS queries timeout; iodine/dnscat2 fail to establish; Suricata ET DNS alert on entropy test
RT-03 DMZ Reverse Shell	T1059, T1071.001, T1090.003, T1021	Any VM on VLAN 30 (DMZ)	D-99 blocks all DMZ→internal TCP; Suricata detects HTTPS C2 JA3 fingerprint via Wazuh

Table 10. OSIM Validation Scenarios — Adversary Position, Techniques, and Pass Criteria

Evidence Requirements

Each validation exercise produces a governance record with the following mandatory fields: exercise ID, date, operator name, ATT&CK; techniques tested, written detection hypothesis (before exercise begins), pass/fail per step, Wazuh alert IDs exported from dashboard, Suricata eve.json excerpt, gaps identified,

remediation required flag, and snapshot revert confirmation. A scenario is not marked as passing until the Wazuh alert export is confirmed and attached to the record.

IPS Promotion Criteria

Suricata is initially deployed in IDS mode (observe and alert). Promotion to IPS mode (inline drop) requires all of the following to be confirmed:

- VLAN de-encapsulation verified via tcpdump and eve.json VLAN field presence (Section 12.1 procedure)
- False positive rate below 5 alerts/day on ET Open ruleset, sustained for 14 consecutive days
- All suppressed SIDs documented with justification — zero undocumented suppressions
- Wazuh receiving and parsing eve.json correctly — test alert visible with full field mapping
- Proxmox snapshot of OPNsense VM taken and confirmed before IPS mode enable

SECTION 11

Governance and Change Management

Treating firewall configuration as a versioned, auditable engineering artifact.

Security architecture without governance is aspirational documentation. OSIM treats governance as an engineering discipline with the same rigor applied to software development: version control, automated testing, hash verification, and a formal change record for every modification. The goal is not bureaucracy — it is making the security posture of the environment knowable, verifiable, and auditable at any point in time.

Firewall as Code

The OPNsense configuration is treated as a code artifact. Every change follows a defined procedure: export the current configuration, compute and record its SHA-256 hash, make the change, re-export, re-hash, run the invariant verification script, commit both configurations and hashes to version control with a change ticket reference in the commit message. No change is complete until the invariant check returns all TRUE.

Process Step	Action	Tool / Location
1 — Pre-change export	Export running config and record SHA-256	OPNsense GUI or SSH; governance/config-hashes.log
2 — Change execution	Implement rule addition/modification/removal	OPNsense GUI or config XML edit
3 — Invariant check	Run automated invariant verification script	validation/run-validation.py; must return all TRUE
4 — Post-change export	Export new config and record new hash	governance/config-hashes.log; diff from previous
5 — Git commit	Commit config + hashes with change ticket ID	git commit -m 'CHANGE-NNN: [description]'
6 — Change record	Complete governance/change-log.md entry	Includes rationale, operator, hash before/after, invariant result
7 — Drift monitoring	Daily cron compares live hash to Git baseline	INV-09; mismatch triggers Wazuh alert immediately

Table 11. Firewall Change Management Process — Seven-Step Procedure

Quarterly Review Checklist

- Validate all active PASS rules have documented business justification
- Remove orphaned rules for decommissioned hosts from aliases and rule sets
- Review DNS_RESOLVERS alias for stale or missing gateway IPs
- Audit all PASS rules against least-privilege principle — verify ports are still appropriate
- Confirm no ANY-ANY rules exist on any interface (INV-01 verification)
- Verify Wazuh is receiving logs from all five VLANs — check agent heartbeat status
- Confirm Suricata alert volume is within baseline; review all suppressed SIDs have documentation
- Revalidate NAT-IN port forwards have active, current recipients
- Test default-deny terminators fire and log correctly — generate blocked test traffic
- Review MGMT-A→MGMT-B rule scope — confirm 8006/22/443 still appropriate for current operations

SECTION 12

Architecture Evolution Roadmap

Closing residual risks and advancing toward a Zero Trust posture.

The current OSIM reference implementation achieves LOW residual risk across the majority of its threat boundaries. Two MEDIUM residual risks remain, each with a clear mitigation path. The roadmap below describes the engineering initiatives required to close those residuals and advance the architecture toward a mature Zero Trust posture. Initiatives are prioritized by security impact and implementation feasibility.

Residual Risk Summary

Accepted Residual Risk 1 — MGMT-A to MGMT-B Lateral Movement (MEDIUM): Administrative workstation access to infrastructure is port-restricted to three services (Proxmox UI on 8006, SSH on 22, OPNsense management on 443) but not fully blocked. A compromised admin workstation with valid credentials can authenticate to those services. Mitigation: Privileged Access Workstations with MFA enforcement on all Tier 0-Infra interfaces.

Accepted Residual Risk 2 — HTTPS C2 Egress from LAB/DMZ (MEDIUM): Outbound TCP 443 is required for legitimate operations and cannot be blocked at the port level. An attacker may establish command-and-control over permitted HTTPS. Suricata TLS metadata inspection (JA3, certificate anomaly detection) is the sole detection control. Mitigation: TLS inspection proxy providing content-level inspection of encrypted egress.

Maturity Roadmap

Initiative	Category	Impact	Priority	Effort
Deploy Privileged Access Workstations (PAW) with MFA enforcement on all Tier 0-Infra interfaces	**Access Control**	Closes MEDIUM residual risk on MGMT-A→MGMT-B boundary	High	Medium
TLS inspection proxy (Squid SSL bump) for LAB and DMZ egress	**Egress Inspection**	Closes MEDIUM residual risk on HTTPS C2 egress channel	High	High
Automated invariant CI check (INV-01 through INV-10 scripted verification)	**Governance**	Reduces manual audit burden; catches drift immediately	High	Medium

Initiative	Category	Impact	Priority	Effort
Response Policy Zone (RPZ) on Unbound for known C2/malware domains	**DNS Security**	Second layer of DNS-based threat containment beyond firewall block	Medium	Low
Per-VLAN DNS resolver restriction (eliminate cross-VLAN Unbound queries)	**DNS Security**	Tightens DNS_RESOLVERS model to strict least-privilege	Medium	Low
RT-03 automated execution agent on dedicated DMZ test VM	**Validation**	Enables fully automated three-scenario validation pipeline	Medium	Medium
Network packet broker for SPAN-based out-of-band IDS deployment	**Detection**	Decouples IDS from firewall VM; survives OPNsense restart	Low	High
Zero Trust identity layer (identity-aware proxy for Proxmox/OPNsense access)	**Zero Trust**	Eliminates credential-only access to Tier 0-Infra management interfaces	Low (future)	High

Table 12. Architecture Evolution Roadmap — Priority, Impact, and Effort

Zero Trust Evolution Path

OSIM's current implementation represents Zero Trust at the network layer. The natural evolution is to extend Zero Trust principles to the identity and application layers:

- **Phase 1 (Current):** Network-layer Zero Trust via VLAN segmentation, default-deny enforcement, and explicit-allow policy. No implicit trust granted by zone membership.
- **Phase 2 (PAW + MFA):** Identity-layer controls on Tier 0-Infra access. PAWs with hardware security keys. MFA enforced on Proxmox and OPNsense. Closes MEDIUM residual risk 1.
- **Phase 3 (TLS Inspection):** Application-layer visibility on encrypted egress. Squid SSL bump proxy enables content inspection. Closes MEDIUM residual risk 2.
- **Phase 4 (Identity-Aware Proxy):** Zero Trust Network Access (ZTNA) for administrative access to Tier 0-Infra. Every access request evaluated against identity, device posture, and request context — not merely network position.
- **Phase 5 (Continuous Verification):** Automated continuous invariant verification integrated into CI/CD-style pipeline. Every infrastructure change validated against the full invariant set before merge. Security posture becomes a first-class CI artifact.

Framework Evolution:
OSIM is designed to be environment-agnostic. The architectural principles, invariant model, and governance procedures described in this portfolio apply equally to enterprise networks, cloud infrastructure, hybrid environments, and security operations platforms. The reference implementation on OPNsense and Proxmox demonstrates the methodology — it is not a prerequisite. Any organization can apply OSIM principles to their existing infrastructure by adopting the zone model, alias-based rule construction, invariant verification, and governance-first change management as engineering disciplines.

FRAMEWORK SUMMARY

What OSIM Demonstrates

Systems Thinking	OSIM treats security as a systems property, not a tool property. The architecture is designed so that security properties emerge from the system's structure — not from the vigilance of its operators.
Engineering Rigor	Every design decision has a documented rationale. Every security property is expressed as a machine-verifiable invariant. Every change follows a defined governance procedure. The security posture is knowable at any point in time.
Operational Maturity	Detection is not bolted on after the fact. It is designed in from the start as a four-layer model where structural controls provide the foundation and behavioral correlation provides the sensitivity.
Adversarial Validation	Security properties are not assumed to hold — they are proven through structured red team exercises aligned to MITRE ATT&CK.; A control that has not been validated is not a control.
Governance Discipline	The firewall configuration is a versioned code artifact. Drift is detected automatically. Changes require documentation and post-change invariant verification. Security policy is auditable, not aspirational.

Alec Sanchez · Security Architecture Portfolio · OSIM v1.0 · 2026